

Préconisations AD

1. Architecture et Cloisonnement Logique (Modèle en Tiers)

- Zone Cœur de Confiance (Niveau 0) : Regroupe tout ce qui contrôle l'identité (contrôleurs de domaine, serveurs d'authentification, administrateurs du domaine). Cette zone inclut aussi les infrastructures qui les hébergent : hyperviseurs, baies de stockage et serveurs de sauvegarde spécifiques au Niveau 0.
- Zone Serveurs Métiers (Niveau 1) : Contient les applications et serveurs de données critiques de l'entreprise.
- Zone Utilisateurs et Bureautique (Niveau 2) : Comprend les postes de travail et les comptes des utilisateurs standards.
- Règle d'étanchéité stricte : Aucun compte d'un niveau supérieur ne doit jamais se connecter sur un système d'un niveau inférieur. Les secrets d'un administrateur (Niveau 0) ne doivent jamais transiter ou être stockés sur un poste de travail (Niveau 2).

2. Gestion des Identités et des Privilèges

- Authentification Forte (MFA) : Généraliser l'authentification à plusieurs facteurs pour tous les accès, en priorité pour les administrateurs et les accès distants (VPN, Cloud).
- Principe du Moindre Privilège : Limiter le nombre d'administrateurs au strict minimum. Utiliser des comptes nominatifs plutôt que des comptes partagés.
- Administration à la demande : Privilégier des solutions où les privilèges sont accordés temporairement et limités à la tâche à accomplir.
- Protection des Secrets : Utiliser des coffres-forts de mots de passe. Activer les protections mémoires pour empêcher l'extraction des hachage de mots de passe .
- Nettoyage des Droits : Auditer régulièrement les droits pour supprimer les accès obsolètes ou excessifs.

3. Infrastructure d'Administration Sécurisée

- Postes d'Administration Dédiés (PA) : Utiliser des machines physiques isolées pour administrer le Niveau 0. Ces postes ne doivent avoir ni accès à la messagerie, ni accès à Internet.
- Serveurs de Rebond : Passer par des bastions d'administration sécurisés pour accéder aux serveurs, avec une journalisation complète des actions effectuées.
- Forêt d'Administration : Pour les environnements très sensibles, créer une structure d'identité totalement séparée et dédiée uniquement à la gestion de l'infrastructure principale.

4. Durcissement Technique et Protocoles

- Sécurisation des Flux : Désactiver les protocoles obsolètes et non sécurisés (comme NTLMv1 ou SMBv1). Imposer la signature et le chiffrement des flux SMB et LDAP.
- Renforcement du Protocole Kerberos : Utiliser des clés de chiffrement fortes (AES), surveiller les requêtes inhabituelles et protéger les comptes de service contre les attaques de force brute.
- Durcissement des OS : Désactiver les services inutiles. Appliquer des politiques de restriction logicielle pour n'autoriser que les exécutables connus.
- Sécurisation de la Virtualisation : Isoler les réseaux de gestion des hyperviseurs et durcir l'accès aux consoles d'administration des machines virtuelles du Niveau 0.

5. Hygiène Opérationnelle et Surveillance

- Maintien en Condition de Sécurité : Appliquer les correctifs de sécurité critiques dans un délai très court (24h à 48h pour les failles majeures).
- Sauvegardes Hors-Ligne : Maintenir des sauvegardes régulières, testées, et surtout déconnectées du réseau pour garantir la reconstruction du système en cas d'attaque par rançongiciel.
- Journalisation centralisée : Collecter et analyser les logs de manière centralisée. Surveiller spécifiquement les modifications de groupes d'administration et les connexions anormales.
- Inventaire Exhaustif : Maintenir une connaissance précise de tous les équipements, logiciels et comptes présents sur le réseau.
- Antivirus et EDR : Déployer des outils de détection et de réponse sur les points de terminaison pour bloquer les comportements suspects en temps réel.

6. Stratégie "Zéro Confiance" (Zero Trust)

- Vérification systématique : Chaque demande d'accès doit être vérifiée en fonction du contexte.
- Micro-segmentation : Isoler les flux réseau au niveau le plus fin possible pour empêcher tout mouvement latéral d'un attaquant entre deux serveurs d'une même zone.

7. Sécurité des environnements Hybrides et Cloud

- Synchronisation Sécurisée : Limiter les objets synchronisés entre l'annuaire local et le cloud au strict nécessaire. Les comptes d'administration de haut niveau ne doivent jamais être synchronisés pour éviter qu'une compromission dans un environnement n'entraîne la chute de l'autre.
- Accès Conditionnel : Mettre en place des règles vérifiant dynamiquement la conformité de l'appareil (antivirus à jour, chiffrement actif) et la localisation avant d'autoriser l'accès aux ressources cloud.
- Gestion des Identités de Service : Inventorier et surveiller les services principaux et les applications enregistrées, qui sont souvent des cibles pour contourner l'authentification forte.

8. Maîtrise des Flux Réseaux et des Protocoles Bas Niveau

- Désactivation de la Résolution de Noms Archaïque : Désactiver les protocoles LLMNR et NetBIOS qui permettent à un attaquant de se faire passer pour un serveur légitime sur le réseau local.
- Micro-segmentation du Datacenter : Ne pas se contenter de séparer les zones, mais isoler les serveurs les uns des autres au sein d'une même zone pour interdire tout flux qui n'est pas explicitement requis par l'application.

9. Stratégies de Détection Avancée et Déception (Honeypots)

- Utilisation de Honey Tokens : Créer de faux comptes d'administration ou de faux fichiers mot_de_passe.txt extrêmement attractifs mais inutilisés. Toute tentative d'accès à ces objets doit déclencher une alerte immédiate et critique.
- Surveillance des modifications de Groupes : Alerter en temps réel pour toute modification dans les groupes de sécurité sensibles, même si l'action semble légitime.
- Analyse des comportements anormaux (UEBA) : Utiliser des outils capables de détecter des connexions à des heures inhabituelles ou depuis des machines non habituelles, même avec des identifiants valides.

10. Résilience Organisationnelle et Facteur Humain

- Exercices de Crise : Organiser régulièrement des simulations d'attaques (type rançongiciel) impliquant non seulement la technique, mais aussi la direction et la communication.
- Sensibilisation ciblée : Former spécifiquement les administrateurs aux techniques d'attaque avancées (Pass-the-Hash, Kerberoasting) pour qu'ils comprennent l'importance des mesures de durcissement.
- Procédure de Reconstruction : Rédiger et tester un plan de reconstruction à partir de zéro (Bare Metal Recovery) de l'annuaire d'identité, en s'assurant que les supports de sauvegarde sont protégés contre toute modification ou suppression.

11. Intégrité Logicielle et Chaîne de Développement

- Signature de Code : Interdire l'exécution de scripts (PowerShell, Python) qui ne sont pas signés numériquement par l'organisation.
- Sécurisation des Pipelines d'Automatisation : Les serveurs de déploiement automatique ayant souvent des droits très élevés, ils doivent être considérés comme faisant partie du Niveau 0 et protégés en conséquence.
- Whitelisting Applicatif : Sur les serveurs critiques, passer d'un mode blocage des logiciels malveillants à un mode autorisation exclusive des logiciels nécessaires.

12. Sécurité Physique des Nœuds Critiques

- Protection des Contrôleurs de Domaine : Les serveurs hébergeant l'annuaire doivent être dans des baies verrouillées, au sein d'un local sécurisé avec contrôle d'accès biométrique ou par badge, et sous surveillance vidéo.
- Chiffrement des Disques : Chiffrer systématiquement les disques durs de tous les serveurs et postes de travail pour éviter le vol de données en cas de vol physique du matériel.
- Neutralisation des Ports Physiques : Désactiver les ports USB et autres interfaces non nécessaires sur les serveurs sensibles pour empêcher l'injection de code via des périphériques malveillants.